Lecture 4: Security Economics

Security Engineering (622.755) – Lernzettel 08.11.2026

Nur Folien: Ein passendes Transkript fehlt; Seitenverweise meinen PDF-Seiten.

1. Muss ich wissen

Game Theory: Was wird modelliert? (Folien S. 8, 11–12, 54)

- **Game Theory** untersucht Kooperation und Konflikt unabhängiger Entscheidungsträger, deren Entscheidungen die Reaktionen anderer berücksichtigen müssen.
- **PAPI** steht für Players, Actions, Payoffs und Information Structure: Akteure, Aktionen, Nutzen und verfügbare Information.
- **Rationality** bedeutet im Modell, den eigenen erwarteten Payoff zu maximieren, nicht den gemeinsamen Nutzen.
- **Strategische Abhängigkeit** liegt vor, wenn die beste eigene Entscheidung davon abhängt, was andere tun.

Spieltypen auseinanderhalten (Folien S. 10, 55)

- **Perfect Information** bedeutet nach der Foliendefinition, dass der vollständige Spielzustand bekannt ist, wie beim Schach.
- **Imperfect Information** bedeutet, unter begrenzter Information entscheiden zu müssen, wie beim Poker.
- **One-shot / Repeated** unterscheidet einmaliges Spielen von wiederholten Begegnungen.
- **Simultaneous / Sequential** unterscheidet gleichzeitige Entscheidungen von einer Zugfolge.

Strategy und Normal Form (Folien S. 13–16)

- Eine **Strategy** ist ein vollständiger Handlungsplan für jedes Information Set, auch wenn dieser Entscheidungspunkt nie erreicht wird.
- Die **Normal Form** stellt Strategien und zugehörige Payoffs in einer Matrix dar.
- **Zeilen** gehören zu Player 1, Spalten zu Player 2 und das Tupel (u_1, u_2) nennt zuerst den Nutzen des Zeilenspielers.
- Im **Zero-sum Game** entspricht der Gewinn eines Spielers dem Verlust des anderen, wie bei Matching Pennies.

Strict Dominance erkennen (Folien S. 17–20, 56)

- Eine **strictly dominated Strategy** ist bei jeder gegnerischen Strategiewahl schlechter als eine bestimmte andere eigene Strategie.
- Eine **strictly dominant Strategy** ist umgekehrt bei jeder gegnerischen Wahl besser als jede eigene Alternative.
- Bei **Iterated Elimination** werden strikt dominierte Strategien gestrichen und die verbleibenden Möglichkeiten erneut verglichen.
- **Vergleichsregel:** Für Player 1 innerhalb jeder Spalte die ersten Zahlen vergleichen, für Player 2 innerhalb jeder Zeile die zweiten Zahlen.

1. Muss ich wissen – Equilibria

Nash Equilibrium: Nur allein abweichen (Folien S. 21–22, 35, 57)

- Ein **Strategy Profile** enthält je eine Strategie pro Spieler.
- Ein **Nash Equilibrium (NE)** ist ein Profil, in dem niemand durch einen einseitigen Strategiewechsel seinen Payoff verbessern kann.
- Eine **Best Response** ist die beste Antwort auf festgehaltene Strategien der anderen, und im NE sind alle Strategien gegenseitige Best Responses.
- **Pure Strategies** legen eine Strategie fest, während **Mixed Strategies** Wahrscheinlichkeiten über reine Strategien vergeben.
- **Existenz:** Ein endliches Matrixspiel besitzt ein NE, aber nicht zwingend eines in reinen Strategien.

Prisoner's Dilemma: Individuell gegen kollektiv (Folien S. 24–28, 55, 58)

- **Beide deny:** Beide erhalten jeweils ein Jahr Haft.
- **Einer confess, einer deny:** Der Geständige kommt frei, der andere erhält sechs Jahre Haft.
- **Beide confess:** Beide erhalten jeweils drei Jahre Haft.
- **Dominanzprüfung:** Bei gegnerischem deny ist frei besser als ein Jahr, bei gegnerischem confess sind drei Jahre besser als sechs Jahre.
- **Ergebnis:** (confess, confess) ist das Dominant Strategy Equilibrium, obwohl beide mit gemeinsamem deny besser gestellt wären.

Pareto Efficiency ist nicht Nash und nicht Fairness (Folien S. 23, 39, 58)

- Eine **Pareto Improvement** stellt mindestens eine Person besser, ohne jemanden schlechterzustellen.
- Eine **Pareto Efficient Allocation** lässt keine solche Verbesserung mehr zu.
- Ein **Social Optimum** maximiert den Gesamtnutzen und muss Pareto-efficient sein, während Pareto Efficiency allein keine Fairness garantiert.
- **NE ist nicht automatisch Pareto-efficient:** Im Prisoner's Dilemma verbessert der gemeinsame Wechsel von confess zu deny beide Spieler, obwohl ein einseitiger Wechsel nicht hilft.
- **Mechanism Design** verändert Spielregeln oder Anreize, damit individuell sinnvolle Entscheidungen besser zum kollektiven Ziel passen.

1. Muss ich wissen – Markets

Security Economics: Wer entscheidet, wer zahlt? (Folien S. 3–5)

- Das **Agency Problem** beschreibt, dass Beschäftigte ihren eigenen Nutzen statt automatisch den Nutzen ihres Arbeitgebers optimieren.
- **Misaligned Incentives** entstehen etwa, wenn Alice schützt, aber Bob die Kosten eines Sicherheitsversagens trägt.
- **Economic Analysis** untersucht fehlende Kooperation, Marktmacht und Marktversagen als Ursachen von Security Failures.
- **Analysis und Data** helfen, Schäden zu quantifizieren, Gegenmaßnahmen zu priorisieren und Policy zu beeinflussen.

Competitive Equilibrium und Welfare Theorems (Folien S. 38–40, 59–60)

- Im **Competitive Equilibrium** entsprechen sich Angebot und Nachfrage zum Marktpreis, den kein einzelner Käufer oder Verkäufer allein verändern kann.
- Das **First Welfare Theorem** ordnet dem Marktgleichgewicht unter den Modellbedingungen Pareto Efficiency zu.
- Das **Second Welfare Theorem** beschreibt laut Folien die Erreichbarkeit einer Pareto-optimalen Allokation durch Marktkräfte bei konvexen Präferenzen.
- Die **Bedingungsliste der Folien** umfasst rationale Akteure, klar definierte Property Rights ohne Externalities, vollständige Information, keine Transaction Costs und konvexe Präferenzen.
- **Grenzen:** Information Asymmetry, Monopolmacht, Externalities, Transaction Costs und irrationales Verhalten verletzen die idealisierten Bedingungen.

Externalities und Public Goods (Folien S. 43–44, 61)

- **Externalities** sind für andere relevante Nebenwirkungen, die nicht direkt gehandelt beziehungsweise vollständig über Property Rights zugeordnet werden.
- Eine **negative Externality** ist etwa ein IoT-Gerät im Botnet, eine **positive Externality** sind etwa technische Standards.
- **Effizienzfolge:** Bei Externalities ist Pareto Efficiency eines Competitive Equilibrium nicht mehr gesichert.
- Ein **Public Good** ist non-rivalrous und non-excludable, wie wissenschaftliches Wissen.
- **Free-riding** bedeutet, von der Arbeit anderer zu profitieren, ohne selbst beizutragen, wie im Folienbeispiel OpenSSL oder Python.

Network Externalities (Folien S. 45, 61)

- **Network Externalities** erhöhen den Nutzen eines Netzwerks für einzelne Nutzer, wenn mehr Menschen daran teilnehmen.
- **Metcalfe's Law** setzt vereinfacht den Netzwerkwert proportional zur Nutzerzahl im Quadrat, wobei die Realität laut Folie komplexer ist.
- **Lock-in** kann entstehen, wenn der Wert des großen bestehenden Netzwerks den Wechsel zu einer Alternative unattraktiv macht.

1. Muss ich wissen – Information Markets

Low Marginal Costs und Technical Lock-in (Folien S. 42, 47–49, 62)

- **Marginal Cost** bezeichnet die Kosten einer weiteren Informationskopie, die im Folienmodell null sind und Wettbewerbspreise sowie Monetarisierung unter Druck setzen.
- **Technical Lock-in** entsteht durch Bindungen wie ergänzende Apps, erlernte Bedienkenntnisse, Cloud Services oder Subscriptions.
- **Switching Costs** sind die beim Anbieterwechsel entstehenden Kosten und Mühen.
- Das **Fundamental Theorem of Information Goods** setzt nach Shapiro/Varian in den Folien den Nettobarwert einer Kundenbasis ihren gesamten Switching Costs gleich.
- **Dominant-firm Markets** werden durch niedrige Marginal Costs, Technical Lock-in und Network Externalities begünstigt, gemeinsam besonders stark.

Vendor Security versus User Security (Folien S. 49–50)

- Der **Wettlauf um Market Share** kann frühe Markteinführung gegenüber späterer Produktqualität priorisieren.
- **Two-sided Markets** müssen auch die andere Marktseite ansprechen, etwa Werbetreibende statt nur Nutzer.
- **Security-Konflikt:** Die Anreize des Anbieters müssen deshalb nicht mit den Schutzinteressen seiner Nutzer übereinstimmen.

Asymmetric Information und Signalling (Folien S. 51–52, 62)

- **Asymmetric Information** liegt vor, wenn eine Seite mehr über die relevante Qualität oder das Verhalten weiß als die andere.
- Im **Market of Lemons** können Käufer gute und schlechte Gebrauchtwagen nicht unterscheiden, wodurch verborgene Qualität das Marktergebnis beeinflusst.
- **Signalling** macht Qualität durch ein erkennbares Signal glaubhafter, etwa eine Garantie, die einem Anbieter guter Autos günstiger kommt.
- **Adverse Selection** ist das Hidden-information-Problem, bei dem ein Informationsvorsprung über Produkt oder Dienstleistung in einer Transaktion ausgenutzt wird.
- **Moral Hazard** ist das Hidden-action-Problem, bei dem jemand nach einer Vereinbarung sein Verhalten ändert, weil er die Folgen nicht selbst zu tragen glaubt.

Versicherungsbeispiel sicher unterscheiden (Folien S. 52)

- **Adverse Selection:** Bereits riskant fahrende Personen kaufen das sichere Auto, um Unfälle eher zu überleben.
- **Moral Hazard:** Personen fahren erst wegen der zusätzlichen Sicherheit schneller.
- **Gegenanreize** sind Selbstbehalt und No-claim Bonus, die eigenes Risiko wieder spürbar machen.
- **Cyber Insurance** hat unter anderem das Problem, den tatsächlichen Security-Zustand einer Firma zu beurteilen.

2. Hinweise der Lehrperson

Ausschließlich Angaben aus diesem Foliensatz, keine transkribierten Aussagen.

Lernfokus und Testform laut Folien (Folien S. 56, 63)

- **Lernfokus:** Die Fragen am Ende und besonders deren Definitionen stehen im Mittelpunkt, dennoch soll das gesamte Skriptum gelernt werden.
- **Minitest:** Die Folie nennt ein Moodle Quiz mit zwei bis drei Fragen in fünf Minuten zu Vorlesungsbeginn, außer in der ersten Vorlesung.
- **Fragetypen:** True/False, Multiple Choice, Fill in Text und Mathematical Computations werden genannt.
- **Wertung:** Zwölf Tests mit je fünf Punkten sind vorgesehen, die neun besten zählen bis maximal 45 Punkte.
- **Spielrechnung:** Auf der Dominanz-Fragenfolie steht, dass ein Spiel im Minitest vorkommen kann und drei Punkte wert ist.

Ausschluss und Datumsgrenzen (Folien S. 1, 33–34, 53)

- **Not for minitest** steht ausdrücklich auf der statischen Hawk–Dove-Herleitung und auf Replicator Dynamics, nicht auf allen Game-Theory-Folien.
- **Keine aktuelle Terminbestätigung:** Die Fragenfolie nennt den ersten Minitest am 7. November, während dieser Auftrag dem 8. November zugeordnet ist.
- **Quellengrenze:** Die Titelseite trägt noch 25W und ein passendes Lecture-4-Transkript fehlt, weshalb daraus keine mündlichen Hinweise oder aktuellen Kalendertermine abgeleitet werden.

3. Gut zu wissen

Repeated Games und Kooperation (Folien S. 27–29)

- **Tit-for-Tat** beginnt kooperativ und übernimmt danach jeweils den vorherigen Zug des Gegners.
- **Noise** kann wechselseitige Defection verfestigen, weshalb gelegentliches Vergeben wieder Kooperation ermöglichen kann.
- **Regulatory Interventions** können langfristige Wiederholung, gegenseitigen Nutzen und geänderte Anreize fördern.

Hawk–Dove: Ergänzung, Herleitung nicht Teststoff (Folien S. 30–34)

- **Doves** teilen Ressourcen, **Hawks** versuchen alles zu nehmen, und Hawk gegen Hawk riskiert einen verlustreichen Kampf.
- v **und** c bezeichnen Ressourcenwert und Kampfkosten, wobei bei $v > c$ die Population zu Hawks tendiert.
- Für $c > v$ nennt die Folie eine gemischte Population mit Hawk-Anteil v/c, ohne dass hier die ausgeschlossene Herleitung verlangt wird.

Anwendungen und Lesestoff (Folien S. 9, 64)

- **Security-Anwendungen** sind Network Hardening, Honeypot Allocation, Patrolling, Moving Target Defense und Cyber Insurance.
- **Vertiefung:** Die Folien verweisen auf Kapitel 8, Economics, in Ross Andersons *Security Engineering*, Third Edition.

4. Selbsttest

Zehn kurze Fragen mit Antworten im Stil der Fragenfolien S. 54–62.

1. **Was umfasst PAPI, und was heißt rational?**
   Players, Actions, Payoffs und Information Structure; rationale Spieler maximieren ihren eigenen erwarteten Payoff.

2. **Welche drei Unterscheidungen von Spieltypen werden genannt?**
   Perfect/Imperfect Information, One-shot/Repeated und Simultaneous/Sequential.

3. **Wie lautet das Dominant Strategy Equilibrium der Matrix auf S. 56?**
   Player 1 wählt bottom: $57 > 45$ bei left und $40 > 28$ bei right; Player 2 wählt right: $57 > 45$ bei Top und $40 > 28$ bei bottom; Ergebnis: $(\text{bottom}, \text{right})$ mit Payoffs $(40, 40)$.

4. **Welche reinen NE besitzt die Matrix auf S. 57?**
   Bei $(\text{Top}, \text{left})$ sind $1 > 0{,}5$ und $3 > 0{,}5$, bei $(\text{bottom}, \text{right})$ sind $3 > 0{,}5$ und $1 > 0{,}5$; beide sind NE, während in den anderen beiden Zellen ein Spieler profitabel wechseln kann.

5. **Warum zeigt das Prisoner's Dilemma, dass NE nicht Pareto Efficiency garantiert?**
   Beide wählen individuell confess und erhalten je drei Jahre, obwohl gemeinsames deny mit je einem Jahr beide besserstellt.

6. **Welche Bedingungen nennen die Folien für Market Efficiency?**
   Rationale Akteure, klare Property Rights ohne Externalities, vollständige Information, keine Transaction Costs und konvexe Präferenzen.

7. **Was ist eine Externality, und welches Security-Beispiel wird genannt?**
   Eine nicht direkt gehandelte Nebenwirkung für andere; ein IoT-Gerät im Botnet erzeugt eine negative Externality.

8. **Was trennt Public Goods von Network Externalities?**
   Public Goods sind non-rivalrous und non-excludable; Network Externalities bedeuten steigenden Nutzernutzen durch zusätzliche Netzwerkteilnehmer.

9. **Welche drei Faktoren begünstigen dominante Anbieter in Information Markets?**
   Niedrige Marginal Costs, Technical Lock-in und Network Externalities.

10. **Wie unterscheidet man Moral Hazard von Adverse Selection?**
    Moral Hazard betrifft Hidden Action nach der Vereinbarung, Adverse Selection betrifft Hidden Information über Produkt oder Dienstleistung bei der Transaktion.